

Organización:	Optim AI Improvement, S.L. (OptimTech)					
1. Objetivo:	Auditar internamente el nivel de implantación del sistema de gestión de la seguridad de la información con el fin de: - Determinar la conformidad del sistema de gestión de la organización auditada con los criterios de auditoría. - Evaluar su capacidad para cumplir con los requisitos legales, reglamentarios y contractuales aplicables. - Evaluar su eficacia para cumplir los objetivos especificados y cuando corresponda, identificar posibles áreas de mejora de la organización					
2. Alcance:	Alcance certificación	Lleida.net				
	Intervalo de tiempo	Últimos 12 meses				
	Ciclo de certificación	Certificación inicial				
3. Criterios de auditoría:	- Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad. (ENS) - Categoría del sistema: MEDIA - Políticas, procedimientos y normativas internas					
4. Lugar, fechas y horarios:	Ubicaciones	Auditoría en remoto sobre emplazamiento virtual				
	Fechas	12/11/2025 de 9:00 a 18:00h 13/11/2025 de 9:00 a 18:00h				
5. Métodos a utilizar:	X	Revisión documental	X	Observación directa procesos	X	Remoto / Teleconferencia
		Utilización cuestionarios	X	Entrevistas	X	Observación datos históricos
	X	Muestreo	X	Auditorías previas		
6. Equipo auditor:	Líder equipo auditor:	Toni Ripoll, Auditor de Sistemas de Gestión de Seguridad de la Información – ENS				
	Personal auditor:					
	Guías y observadores:					
7. Representantes auditados:	- Jordi Roca (CEO) - Marc Muixí (CTO)					
8. Recursos necesarios:		Sala de reuniones		Impresora		Desplazamiento: (opcional)
	X	Videoconferencia	X	Equipo informático		
		Autorización fotografías, video	X	Acuerdo confidencialidad		
9. Observaciones	La auditoría se ha desarrollado íntegramente en remoto dado que la empresa no dispone de ninguna ubicación física y desarrolla totalmente sus actividades mediante servicios en la nube.					

10. NIVEL DE CONFORMIDAD

	El nivel de conformidad del sistema de información es APTO para satisfacer los requisitos del Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad (ENS).
X	El nivel de conformidad del sistema de información es APTO para satisfacer los requisitos del Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad (ENS). Sin embargo, hay que realizar las acciones correctivas necesarias para solucionar las no conformidades detectadas.
	El nivel de conformidad del sistema de información es NO APTO para satisfacer los requisitos del Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad (ENS). Es necesario realizar las acciones correctivas necesarias para solucionar las no conformidades detectadas, y dedicar más recursos a la gestión del sistema.

11. CONCLUSIONES

Aunque la empresa se ha constituido recientemente y diversos procesos no están completamente implementados o adolecen de historial para evidenciar su correcto funcionamiento, se muestra una voluntad de disponer de unos fundamentos sobre los que basar la gestión efectiva de la seguridad que apoye el crecimiento de la de acuerdo con unos altos estándares de seguridad de la información de acuerdo con los requisitos exigibles al sector en el que presta sus servicios la organización, con una actitud positiva y proactiva por parte de los implicados.

Si bien se identifican algunas No Conformidades, en su mayoría se refieren a aspectos que ya están en proceso de implantación, por lo que se determina que existe un nivel de seguridad y cumplimiento bastante elevado que deberá ser confirmado durante la auditoría externa.

Para los aspectos a mejorar documentados como Observaciones se recomienda planificar acciones correctivas o de mejora ya que potencialmente podrían constituir futuras no conformidades.

Por otro lado, se debe tener en cuenta que la auditoría se realiza en base a un muestro y podrían existir No Conformidades no identificadas en este informe, por lo que es recomendable realizar una revisión en profundidad antes de la auditoría externa.

La impresión general es que el sistema tiene un nivel adecuado de seguridad, y que está siendo gestionado e implantada de forma correcta y satisfactoria y sin poner en riesgo la seguridad general del sistema.

En consecuencia, se considera que se dispone de un sistema con un control y grado de cumplimiento suficiente de las normas de referencia de cara a realizar en breve la próxima Auditoría Externa, una vez se hayan subsanado las No Conformidades identificadas, y también se hayan tratado las observaciones identificadas.

12. HALLAZGOS

A continuación, se resumen los hallazgos que se han encontrado en esta auditoría.

El detalle se puede encontrar en el documento *Informe auditoria interna 2025-ENS-OPTIMTECH-Anexo Detalle* que complementa este informe.

NO CONFORMIDADES			
Ref. N.C.	Requisito Norma	Descripción de la No Conformidad	Categoría N.C.
NC-01	Org.1 Art.28 Art.41 Op.pl.1	No se dispone de evidencia de aprobación formal de: - Política de Seguridad de la Información - Categorización del Sistema - Declaración de Aplicabilidad - Análisis de Riesgos	Menor
NC-02	Art. 32 Op.mon.2	No se ha presentado el informe INES. a) No se dispone de evidencias de que se hayan recopilado indicadores para evaluar el comportamiento del sistema de gestión de incidentes, de acuerdo la guía CCN-STIC 817 Gestión de ciberincidentes, en particular el tiempo de resolución del 50% y el 90% de los incidentes de seguridad. b) No se recopilan los datos precisos para conocer la eficiencia del sistema de seguridad, en relación con los recursos consumidos, en términos de horas y presupuesto	Menor
NC-03	Mp.sw.1 Mp. Sw.2	Falta disponer de una metodología general de gestión de proyectos de desarrollo que tenga en cuenta los aspectos de seguridad de la información (requisitos, riesgos, validación, ...) en todo el ciclo de vida	Menor
NC-04	Mp.eq.2 Mp.eq.3	Se utilizan equipos personales sin que haya evidencias de que se aplican suficientes garantías de seguridad tal como: - Cifrado de disco - Bloqueo automático tras periodo de inactividad	Menor
NC-05	Mp.info.6	No se han documentado las políticas concretas de copias de seguridad que se aplican a los diferentes tipos de información. Tampoco se han implementado mecanismos de copia de seguridad en un emplazamiento protegido diferente del de los sistemas de producción, con los niveles de seguridad física y lógica requeridos en función del tipo de información.	Menor
NC-06	Op.exp.8 Op.mon.3	No se dispone de un almacenamiento centralizado de registros de actividad que facilite su análisis y revisión ni se dispone de un sistema automático de recolección de eventos de seguridad que permita la correlación de los mismos. Tampoco se indican los eventos de seguridad que serán auditados y el tiempo de retención de los registros antes de ser eliminado	Menor
NC-07	Mp.s.2 Op.exp.3	No se tiene evidencia de que se hayan ejecutado los análisis de vulnerabilidades y pentest según una planificación definida	Menor

NO CONFORMIDADES			
Ref. N.C.	Requisito Norma	Descripción de la No Conformidad	Categoría N.C.
NC-08	Mp.info.1	No se dispone de evidencias que justifiquen el cumplimiento la legislación en protección de datos personales	Menor

OBSERVACIONES		
Ref. OBS	Requisito Norma	Descripción de la Observación
OB-01	Mp.per.3 Mp.per.4	No existe evidencia de que se estén llevando a cabo o planificando acciones de concienciación y formación
OB-02	Op.exp.6	Si bien se tienen instalado software antimalware en los equipos particulares no se trata de una solución corporativa con consola centralizada de administración y que cumpla: - Se requiere una contraseña de administración o se dispone de cualquier otro mecanismo que impida que el usuario final detenga o altere el funcionamiento de la solución - Escaneo regular de los sistemas para detectar código dañino - Revisar regularmente los informes de resultados generados como consecuencia de los escaneos de los sistemas, así como otra información generada de forma consolidada desde la consola de administración
OB-03	Mp.sw.1	No se tiene evidencia de que mantengan copias de seguridad del código fuente fuera del repositorio en Github
OB-04	Org.2 Mp.per.2	No se dispone de evidencia de la firma del <i>IO1 Normativa de Seguridad de la Información</i> por parte del personal y colaboradores
OB-05	Org.4	No se dispone de evidencia de la autorización firmada para el uso de servicios BYOD a partir del impreso previsto <i>IO5 Autorización uso equipos particulares BYOD</i>
OB-06	Op.acc.1	Si bien está previsto disponer de la lista actualizada de usuarios autorizados para acceder a los diferentes recursos en el <i>Registro TIC de cuentas de usuario</i> , actualmente aún no se ha documentado este registro.
OB-07	Op.acc.6	No se dispone de evidencia de que se limite el número de intentos permitidos, bloqueando la oportunidad de acceso una vez superado tal número
OB-08	Op.exp.2	No se dispone de evidencia de que se haya verificado la configuración según CCN-STIC 884A Guía de Configuración Seguridad para Azure

OPORTUNIDADES DE MEJORA		
Ref. OM	Requisito Norma	Descripción de la Oportunidad de Mejora
OM-1	Mp.info.2	Implementar los mecanismos de etiquetado y protección automática de la información proporcionados por Microsoft Sharepoint
OM-2	Mp.s.2	Implementar un WAF para proteger mejor las aplicaciones web

13. PUNTOS FUERTES

- Alta cultura de la seguridad de la información en la operación y administración de los sistemas de información.
- Implementación de medidas en los sistemas con altos estándares de seguridad.
- Uso de soluciones integradas de Microsoft Azure para proporcionar servicios de seguridad

Firmado:

Toni Ripoll i Roig

15/11/2025

